Auditoría TUTIEMPO para desarrollo

Oct 21, 2026 · @Carlos.

Resumen

El sitio actual funciona, pero el diseño del flujo hace que el cliente reserve por fuera: el teléfono del prestador está a la vista antes de reservar, el registro tiene 7 campos y la comisión no se puede cobrar. Hay además datos de prueba públicos y un email roto en el pie.

El prototipo que acompaña este documento define lo que hay que construir: turnero con seña, una paleta visual por segmento (barberías y peluquerías), panel del barbero (agenda, clientes, finanzas, productos, mensajes automáticos) y cobro dividido con Mercado Pago.

Orden recomendado: primero los 6 arreglos críticos de la sección siguiente (1 a 2 semanas), después el turnero con Mercado Pago, después el panel del barbero.

Actualización: versión multirrubro conectada a Supabase

TuTiempo pasó a ser un marketplace de seis rubros: barberías, peluquerías, masajes, pestañas, uñas y depilación. Una misma persona puede trabajar en varios rubros: aparece en todos, su perfil muestra todos sus servicios agrupados y tiene una sola agenda. Cada rubro tiene una rampa de 11 tonos (50 a 950) de la que salen todos sus colores, incluidos los gráficos de ocupación.

Ya existe una implementación que reemplaza a la del sitio actual (Laravel). Viene en el paquete `TuTiempo-supabase-hostinger.zip`:

Pieza	Qué es	Estado
Base de datos	`supabase/migrations` (6 archivos) o `TODO_EN_UNO.sql`: 25 tablas, RLS en todas, 37 políticas, índices y funciones del servidor	Probada en Postgres 16: 204 controles de seguridad y negocio
Reservas y dinero	Función `book_slot`: valida horario, calcula precio, seña, happy hour y forma de pago (Mercado Pago o efectivo). Restricción `EXCLUDE` contra turnos superpuestos. Reserva "en pago" por 10 minutos	60 reservas simultáneas del mismo horario: 1 gana y 59 son rechazadas

Pieza	Qué es	Estado
Mercado Pago	Edge Functions `mp-create-preference`, `mp-webhook` (con firma verificada), `mp-oauth` y `mp-refunds`	Código listo; falta probar con credenciales reales
App web	Archivos estáticos para Hostinger: `index.html`, `app.js`, `config.js` y `vendor/supabase.js`. Sin servidor propio	Prueba de 95 pasos en navegador real contra la base real
Escala	Listados por cursor e índices; búsqueda de texto completo más tolerancia a errores de tipeo	3 ms por página y menos de 100 ms por búsqueda con 200.000 prestadores y 1.000.000 de turnos

- Seguridad: la clave anon es la única que llega al navegador. Precios, señas y forma de pago se validan en el servidor. El DNI va en un depósito privado. Los tokens de Mercado Pago solo los leen las Edge Functions. Hostinger fuerza HTTPS y aplica una CSP que permite solo scripts propios.
- Lo que falta para producción: probar Mercado Pago con credenciales reales, configurar Auth (Google y la plantilla de email con `{{ .Token }}`), activar `pg_cron` y `pg_net`, y programar con pg_cron los avisos en la app (send_scheduled_notices, ya incluido). WhatsApp se descartó en la versión 28: los avisos van dentro de la app, sin costo.
- El modelo de datos y las reglas de negocio de las secciones siguientes ya están implementados en el SQL. Ante cualquier diferencia, manda el SQL.

Versión 25 (20/10/2026): qué cambió

Pagos (actualizado en la versión 27). Toda reserva exige pagar la seña con Mercado Pago, o el total si el prestador lo pide; la única excepción es el premio de la tarjeta de sellos, que es gratis. El resto lo elige el cliente: efectivo en el local o Mercado Pago. Con la seña paga el turno queda confirmado al instante, sin confirmar asistencia. El prestador decide si acepta el resto en efectivo. A los clientes con faltas sin aviso se les pide el total. No hay saldo TuTiempo ni cashback. book_slot recibe p_pay 'mp', 'cash' (resto en efectivo) o 'reward'.

Comisión (cambiada en la versión 30). La comisión es un % del precio (10% por defecto, la cambia un admin) y la paga el cliente aparte, junto con la seña, en un solo pago de Mercado Pago. El prestador recibe su seña completa. Ejemplo: corte de $20.000 con seña de 50% → el cliente paga $10.000 + $2.000 = $12.000.

Perfil del prestador.

- Foto, rubros y botón Seguir abajo del nombre.
- El precio más bajo ("Desde $X") en el banner y en cada tarjeta del listado.
- Pestañas Servicios / Trabajos / Reseñas. Los trabajos se ven como historias a pantalla completa: avanzan cada 5 segundos, con flechas, Escape y un botón "Reservar turno".
- Sin teléfono: es privado y solo lo ve TuTiempo. Se revocó provider_contact y my_bookings ya no lo devuelve.

Se sacaron:

- Los adicionales por servicio ("Sumá a tu…") y las preguntas antes del turno ("Contale a…").
- Los avisos de retoque.
- El aviso "Te lo recordamos por WhatsApp".

Clientes:

- Foto de perfil.
- Reseñas desde el perfil del prestador o desde Mis turnos, solo de turnos a los que fueron.
- Mensajes de sus profesionales en Mis turnos.

Prestadores:

- Foto de perfil, y subir o borrar trabajos.
- Mensajes a clientes: 5 mensajes listos y editables, con {nombre}, eligiendo a quién con checks. Les llega como notificación dentro de la app (sin WhatsApp desde la versión 28).
- Agregar contactos a mano o desde los contactos del celular (Android).
- En finanzas, lo agendado a mano y lo hecho sin turno van en una sola línea ("Cargados por vos").

Cambio en la base	Detalle
bookings.pay_method	'mp' o 'cash'. En efectivo: seña 0 y confirmado al instante
provider_settings.cash_ok	El prestador acepta o no efectivo
profiles.avatar_path y providers.photo_path	Bucket público "avatars" (2 MB, JPEG/PNG/WEBP). Cada uno sube solo a su carpeta y un trigger impide usar la foto de otro

Cambio en la base	Detalle
client_messages	Solo se crean con send_client_messages: clientes propios con cuenta, 300 por envío y 600 por día. Se leen con my_messages y se marcan con mark_messages_read
cashback_rate() = 0	book_slot ya no usa saldo
Políticas idempotentes	TODO_EN_UNO.sql se puede volver a correr sobre una base con datos para actualizarla. Se probó sobre la versión anterior con los 13 ejemplos

supabase/ejemplos.sql es opcional y carga los 13 prestadores de ejemplo de los 6 rubros, con 33 servicios, horarios y reseñas. Se borran con: delete from providers where slug like 'ej-%'.

Versión 26: tarjeta de sellos

Cada prestador tiene su propia tarjeta. Los sellos son por prestador y por cliente, y no se mezclan entre prestadores.

- **Configuración:** en Panel → Perfil el prestador la activa, elige cuántos sellos (de 15 a 20) y qué servicio regala. Tiene que ser un servicio propio: lo verifica un trigger.
- **Cómo se suman:** cada turno de la app marcado "Asistió" suma 1 sello automáticamente (mark_booking). El prestador también puede sumar 1 a mano desde la ficha, como máximo uno por día por cliente (give_stamp).
- **Canje:** con la tarjeta llena, el cliente reserva el premio gratis con book_slot y p_pay = 'reward'. Solo vale para ese servicio y sin repetición. Si cancela, los sellos vuelven una sola vez. El prestador también puede canjearlo en el local (redeem_stamps). El turno de premio no suma sello.
- **Lo que ve el cliente:** en Mis turnos → Mis sellos, una tarjeta por prestador con los sellos, la cantidad de servicios hechos, cuántos faltan y cuál es el premio. En el perfil del prestador hay un cartel con su progreso.

Cambio en la base	Detalle
provider_settings: stamps_on, stamps_goal (15 a 20), stamps_reward	Configuración de la tarjeta
loyalty_cards	Saldo de sellos por prestador y cliente: sellos, ganados y canjeados. No puede ser negativo

Cambio en la base	Detalle
loyalty_events	Registro de cada movimiento (earn, manual, redeem, refund). Índice único para que un turno no sume ni canjee dos veces
give_stamp, redeem_stamps, my_stamps	Funciones públicas con validación. stamp_add y stamp_refund son internas y están cerradas a la app
RLS	Cada cliente ve solo sus tarjetas y cada prestador solo las de sus clientes. Nadie las edita a mano

Versión 27: seña obligatoria, panel admin, bloqueos y colores

- **Seña obligatoria** en toda reserva, sin importar cómo se pague el resto (efectivo o Mercado Pago). Se sacó el límite de 4 turnos en efectivo porque ya nadie puede reservar sin pagar.
- **Panel de TuTiempo** (tercer modo "Admin"):
  - Tablero del mes: prestadores activos y para verificar, clientes, turnos, facturado, señas, comisión, faltas, tarjetas de sellos, turnos por día y por rubro.
  - Comisión configurable entre 0% y 30%, con 10% por defecto.
  - Ver el DNI de cada prestador, aprobarlo, suspenderlo o reactivarlo.
  - Solo para cuentas de app_admins.
- **Bloquear días o semanas** (Horarios): desde y hasta, o los atajos 1 día, 1 semana, 2 semanas y 1 mes. Se crea un bloqueo por cada día de atención. Los días con turnos no se bloquean y la app avisa cuáles. Se desbloquea por tramo.
- **Tarjeta de sellos:** el prestador elige qué servicios suman sello, además de la cantidad de sellos (15 a 20) y el premio.
- **Colores más suaves:** bajó la saturación de cada rubro y la barbería pasó de negro puro a gris carbón. El contraste del texto sigue por encima de 4.5:1.

Cambio en la base	Detalle
app_settings.commission_pct	Una sola fila, 10 por defecto. commission() la lee y la Edge Function mp-create-preference la usa para el marketplace_fee
admin_stats, admin_providers, admin_set_provider, admin_set_commission	Solo admins (is_admin). La comisión solo cambia con su función

Cambio en la base	Detalle
provider_settings.stamps_services	Servicios que suman sello (null = todos). Un trigger valida que sean del prestador
book_slot	'cash' ahora también cobra la seña; se eliminó too_many_cash

Versión 28: orden por actividad, sellos por servicio, avisos en la app y nuevo tablero admin

Cliente

- **Orden del listado:** primero los más activos, es decir los que más servicios hicieron por la app en los últimos 30 días. Vale para el listado general y para cada rubro. Entre prestadores con la misma actividad sigue el orden rotativo diario.
- **Banner por rubro:** al entrar a un rubro, el texto del banner nombra solo ese rubro.
- **Sin "Desde" repetido:** se quitó el "Desde $X" de la foto.
- **Turnero de 31 días:** de hoy a 30 días adelante, igual para todos. El prestador ya no lo configura.
- **Comisión visible al pagar:** el pago muestra "Incluye comisión TuTiempo (10%)". Ya está dentro del precio, el cliente no paga de más.
- **Confirmación sin datos repetidos:** el aviso principal dice qué servicio se pagó y se quitó la tarjeta repetida de debajo.
- **"No voy a poder ir":** ahora es un botón del mismo tamaño que "Cómo llegar" y "Al calendario".
- **Mis turnos:** primero el próximo turno, después avisos y mensajes, después Mis sellos y al final los anteriores.
- **Turno atendido:** cuando el prestador marca "Asistió", el turno pasa a Anteriores con "+1 sello". El cliente recibe un aviso de gracias en la app.

Tarjetas de sellos (una por servicio)

- Cada servicio tiene su propia tarjeta y su meta (de 15 a 20 sellos). El premio es ese mismo servicio gratis.
- En el perfil, al tocar un servicio se ve la tarjeta de ese servicio.
- El prestador marca qué servicios tienen tarjeta y cuántos sellos pide cada una.
- Los sellos a mano y el canje en el local también van por servicio.

Prestador

- Agenda de 31 días (incluye hoy), semana por semana.

- Se quitó la propina de la caja.
- La solapa Finanzas va al lado de Caja, y la barra de secciones tiene flechas.
- Clientes: los grupos (fieles, cumpleaños, hace 5+ semanas) se agregan con un toque y se sacan con otro.
- Finanzas: se quitaron la línea de comisión pagada, la Meta del mes y la categoría de gastos.
- Horarios: se quitó "¿Cómo trabajás de lunes a viernes?". Al destildar un día aparece "Cerrado".
- Al cargar un servicio, cada campo dice qué es: nombre, duración en minutos y precio.

Sin WhatsApp

Todo aviso al cliente llega como notificación dentro de la app, sin costo por mensaje:

- confirmación al reservar;
- recordatorios 24 h y 2 h antes;
- gracias y pedido de reseña;
- saludo de cumpleaños;
- mensajes del prestador.

A quien no tiene la app no le llega. Las notificaciones push del celular quedan como mejora futura: necesitan claves VAPID y un service worker.

Admin

- La comisión ahora se escribe a mano, de 0 a 30, con decimales (por ejemplo 8,5). Ya no hay botones fijos.
- Tablero nuevo:
  - comisión del mes comparada con los mismos días del mes pasado, y proyección al cierre;
  - 8 indicadores, con la variación de cada uno;
  - gráfico de 30 días con tres vistas: turnos, facturado y comisión;
  - los 5 prestadores más activos y los turnos del mes por rubro;
  - lista "Para revisar" con los DNI pendientes y los prestadores sin Mercado Pago.

Cambio en la base	Detalle
providers.activity + provider_categories.rank_key	Lo suma un trigger cuando un turno de la app pasa a "done". refresh_activity() lo recalcula cada noche (dentro de reshuffle_providers). El orden es rank_key = shuffle_key − activity, con los índices pc_rank y pc_rank_all
services.stamp_goal	Meta de sellos de cada servicio (null = sin tarjeta). loyalty_cards pasa a tener clave (prestador, cliente, servicio). La actualización convierte las tarjetas viejas
give_stamp / redeem_stamps (p_client, p_service)	Por servicio. stamp_add y stamp_refund son internas
client_messages.kind / ref	Avisos automáticos, uno por turno y por tipo. notify_booking() los dispara al confirmar y al marcar Asistió; send_scheduled_notices() corre cada 10 minutos con pg_cron
bookings.app_fee	Comisión cobrada en cada turno. La usa el tablero admin
ahead_days = 31	El turnero queda fijo en 31 días
admin_stats()	Comparación con el mes anterior, 30 días, ranking, rubros y alertas

Versión 29: cierre de caja, bloqueo con cancelación y señas de varios turnos

- **Señas de varios turnos:** si el cliente reserva varios turnos juntos, paga la seña de cada uno. La comisión va dentro de cada seña, y la seña nunca es menor que la comisión: en book_slot, dep = max(seña, ceil(precio × comisión)), con el precio como tope. Así la comisión se cobra en todas las reservas. Después el cliente elige si paga el resto en efectivo o con Mercado Pago.
- **Faltas:** el que falta pierde su seña y nada más. Se quitó el cobro del total a clientes con faltas (strict_no_show queda apagado).
- **Fechas:** todo lo que depende de "hoy" o "ahora" se calcula en hora de Argentina (UTC−3), sin importar la zona del dispositivo (NOW() en la app).
- **Bloquear días o semanas:** block_days() hace todo en una sola transacción:
  - cancela los turnos de esos días (a los de la app con devolución de la seña);
  - avisa al cliente en la app para que reprograme;

    - deja cada día bloqueado;
    - devuelve la lista de clientes cancelados. Antes de confirmar, el prestador ve la lista. En el turnero esos días aparecen "Cerrado", porque provider_busy ahora informa day_block.
- **Arreglo:** al salir del panel del prestador, el turnero podía quedar sin los horarios ocupados durante un minuto. Ya no pasa.
- **Finanzas:**
    - "Caja del día": lo que entró en efectivo y en Mercado Pago, ya sin la comisión, con cierre y efectivo contado.
    - "Mes": gastos fijos cargados una vez, opción de copiar los del mes pasado, balance y cierre del mes.
    - "Año": de 2025 a 2028.
    - Se quitó la vista de 7 días. Tabla nueva: cash_closings, solo para el dueño.
- **Compras de productos:** se cargan solo desde Productos ("Compré más" pide lo que se pagó) y entran solas en los gastos del mes.
- **Estadísticas:** la semana se muestra solo con colores. Se puede avanzar por meses hasta diciembre de 2028, y los años llegan hasta 2028.
- **Listado:** se quitó el texto "N servicios en los últimos 30 días". El orden por actividad sigue igual.
- **Pruebas:** 204 controles de base, 95 pasos en navegador real, carga con 200.000 prestadores y 1.800 clics aleatorios sin errores.

Versión 30 · comisión aparte, panel admin con pestañas y balance

La comisión deja de salir de la seña: el cliente paga seña + comisión y el prestador cobra su seña entera. El panel admin se reordena en 4 pestañas y suma notas privadas, baja de prestadores y el balance de TuTiempo.

- **Comisión aparte:** book_slot guarda la seña que eligió el prestador en `deposit` y la comisión en `client_fee` = round(precio × comisión). Lo que se cobra = seña + comisión de cada turno. confirm_payment exige ese total y guarda `paid_mp` = seña (del prestador) y `app_fee` = comisión. Se quitó la regla "seña nunca menor que la comisión".
- **Edge Function mp-create-preference:** el monto sale de la base (seña + client_fee de cada turno, nunca del navegador) y `marketplace_fee` = suma de client_fee. Hay que volver a publicarla.
- **Devoluciones:** si cancela el prestador (o se lo elimina), se devuelve seña + comisión (`refund_pending`). Si el cliente avisa que no va, la seña queda para el prestador y la comisión para TuTiempo. Turnos viejos (client_fee = 0) siguen con la regla anterior.

- **Checkout:** "Seña para el prestador $10.000 · Comisión TuTiempo (10% del precio) $2.000 · Pagás ahora $12.000", con el resto a pagar en el local debajo. En varios turnos, seña y comisión de cada uno.
- **Admin · Resumen:** se sacó la proyección del mes. El gráfico de 30 barritas se reemplazó por Hoy/Ayer y "Cómo vienen las semanas": 4 bloques de 7 días con fechas, turnos, facturado y comisión en números, y la variación contra la semana anterior.
- **Admin · Prestadores:** divididos por rubro principal (o por nivel de actividad: 30 o más, 10 a 29, 1 a 9, ninguno en 30 días). Cada uno tiene su ficha con notas privadas (tabla `admin_notes`), Suspender y "Eliminar prestador" con doble confirmación (`admin_delete_provider`: cancela turnos futuros con devolución total y aviso, y lo da de baja).
- **Admin · Balance:** comisiones − gastos de TuTiempo = resultado, mes a mes y año a año (2025 a 2028). Detalle del mes: reservas pagadas, cobrado por Mercado Pago, señas para prestadores, comisión y gastos (`admin_expenses`). Cierre de mes (cuando terminó) y de año (cierra los meses que falten) en `admin_closings`, con foto fija de los números y opción de reabrir.
- **Seguridad:** admin_notes, admin_expenses y admin_closings tienen RLS y ningún permiso directo: solo funciones que verifican is_admin. La llave de Mercado Pago de un prestador eliminado se guarda hasta hacer las devoluciones y la borra `purge_deleted_secrets` (mp-refunds y cron nocturno).
- **Pruebas:** test_db 240 controles, e2e 106 pasos, demo 146 controles, 1.800 toques al azar sin errores, y actualización desde v29 sin perder datos.

Versión 31 · meses con candado, bloqueo de días sin devolución automática y Mercado Pago directo

El diseño no cambió (mismo app.css). Cambiaron reglas, textos y la integración de pagos.

- **Finanzas del prestador:** un mes cerrado queda bloqueado (sin agregar, borrar ni copiar gastos, también si se fuerza el botón). "Desbloquear para editar" borra el cierre (`cash_closings`), deja editar y se vuelve a cerrar. Vale para cualquier mes.
- **Bloquear días:** los turnos se cancelan y el cliente recibe el aviso, pero TuTiempo no devuelve la seña: `block_days` deja `refund_pending = 0` y marca `settle_by_provider`. El prestador recibe la lista con teléfono y seña pagada para llamar y devolverla o reprogramar. El cliente ve "se va a comunicar con vos" y no tiene Reprogramar automático. La comisión de esos turnos queda en TuTiempo y cuenta en el balance. Una cancelación suelta del prestador sigue devolviendo todo automáticamente.

- **Mercado Pago, seña al prestador y comisión a TuTiempo:** el cobro se crea con el access token OAuth del prestador, así la seña se acredita en su cuenta. La comisión va en `marketplace_fee` y se acredita en la cuenta dueña de la aplicación (MP_CLIENT_ID), que tiene que ser la de TuTiempo. Mercado Pago descuenta primero su comisión y después la del marketplace (docs de marketplace).
- **Llaves y seguridad del cobro:** el token del prestador dura 180 días y se renueva solo con el refresh_token (`sellerToken` , también en el cron de mp-refunds). Se agregó PKCE S256 en la conexión (OAuth). `binary_mode` y sin pagos en efectivo, para que un pago no quede pendiente más que el horario reservado. El webhook rechaza pagos en otra moneda o cobrados por otra cuenta (`collector_id` distinto del prestador).
- **Revisión del flujo:** `crawl.js` entra a 37 pantallas y toca cada botón uno por uno (471 toques): 0 errores y 0 destinos equivocados. Los 3 toques sin efecto son opciones que ya estaban elegidas. `audit_clicks.py` confirma que cada data-act tiene su acción y cada formulario su envío. Se corrigió "Responder" vacío, que no avisaba nada.
- **Cómo agregar funciones sin romper:** capas separadas (estado, datos demo/en vivo con las mismas funciones `api.m.*` , vistas que solo arman HTML, un manejador de toques y uno de formularios). Cada cambio de base va en una migración idempotente con permiso explícito. Después se corren test_db (244), e2e (107), audit_clicks y crawl.
- **Para actualizar:** volver a correr TODO_EN_UNO.sql (probado desde v30 con datos) y volver a publicar las 4 Edge Functions.

Endurecimiento de seguridad de esta versión

- Antiabuso en book_slot: hasta 5 reservas sin pagar a la vez y 20 intentos por cliente cada 24 horas.
- Ninguna función interna se puede llamar desde el navegador. Se revocó execute a public, anon y authenticated, y solo se volvió a habilitar en las RPC públicas.
- provider_private solo admite actualizar teléfono y objetivo mensual. Con eso, un prestador no puede marcarse mp_connected.
- Fotos: la ruta tiene que estar dentro de la carpeta del propio prestador. No se aceptan ".." ni caracteres raros.
- Frontend: se escapa todo texto de usuario, incluidas las URL de fotos y videos. Hay protección contra doble envío de formularios. Un error inesperado muestra "Algo salió mal · Volver al inicio" en lugar de dejar la pantalla en blanco. Las redirecciones solo van al propio sitio o a Mercado Pago.
- Pruebas: 204 controles de base, 95 pasos en navegador real contra la base real, carga con 200.000 prestadores y 1.000.000 de turnos, y 1.800 clics aleatorios sin errores. Además se probó con nombres maliciosos y no se ejecutó ningún HTML inyectado.

Cuentas e ingreso

Clientes y prestadores usan las mismas cuentas de Supabase Auth. Pantallas: crear cuenta (nombre, email, celular opcional, contraseña y aceptación de términos), ingresar con email y contraseña, Google, código de 6 dígitos por email, "¿Olvidaste tu contraseña?", crear contraseña nueva y "Cambiar contraseña" en Mi perfil.

- Los links de los emails usan token_hash y verifyOtp, así que funcionan aunque el email se abra en otro dispositivo. Son de un solo uso y vencen. La app limpia la dirección después de usarlos.
- Contraseña: mínimo 8 caracteres, con letras y números, y sin el email adentro. La misma regla se configura en Supabase ("Letters and digits"). Hay un medidor de seguridad.
- "Recuperar contraseña" responde igual exista o no el email, para que nadie pueda averiguar quién tiene cuenta.
- Después de 5 intentos fallidos la pantalla se bloquea 30 segundos, además de los límites del propio Supabase.
- Al volver de Google, la app retoma lo que estaba haciendo la persona: el perfil del prestador o el panel.
- El trigger handle_new_user guarda el nombre y el celular del formulario, limpios y recortados.
- Pendiente de configurar en Supabase: plantillas de email (el LEEME tiene el texto exacto), SMTP propio para producción y credenciales de Google. Recomendado: CAPTCHA (Turnstile) al abrir al público.

Alcance y método

Es una auditoría externa: se revisaron las páginas públicas de tutiempo.com.ar entre el 12 y el 14 de octubre de 2026, sin acceso al código, la base de datos ni el servidor. Lo que requiere mirar el código está marcado como "verificar".

Páginas revisadas: inicio, perfiles de prestador (/prestadores/1, 7, 9, 12, 15, 16, 18), /login, /register, /legal/terminos y /robots.txt. Por el meta `csrf-token` y la ruta `/storage/prestadores/fotos/` el stack parece Laravel con Blade (verificar).

Hallazgos críticos del sitio actual

Cinco problemas son de severidad alta: dos exponen datos y tres impiden cobrar o convertir. Están ordenados por severidad.

#	Hallazgo	Dónde	Severidad	Arreglo	Estado
1	Teléfono, dirección e Instagram del prestador visibles sin login, antes de reservar. El cliente arregla por WhatsApp y la plataforma queda afuera.	/prestadores/7	Alta	Mostrar contacto solo después de un turno pagado y confirmado.	Pendiente
2	Cuenta de prueba publicada: "Barbería Juan", Av. San Martín 123, tel. 2284-123456, corte a $200.	/prestadores/1	Alta	Borrar o despublicar cuentas de prueba; campo `is_test` excluido de toda vista pública.	Pendiente
3	La comisión del 20% no se cobra: el pago es transferencia directa al alias del prestador.	Perfil, T&C 4.7	Alta	Mercado Pago Marketplace con split automático (ver Integraciones).	Pendiente
4	El cliente completa 7 campos obligatorios (incluye fecha de nacimiento y sexo) antes de poder reservar. Sin login con Google.	/register	Alta	Google OAuth y registro mínimo: nombre, email, celular.	Pendiente
5	Fotos del DNI subidas en el registro de prestador. Las fotos de perfil se sirven desde `/storage` público; verificar que los DNI no.	/register	Alta	Guardar DNI en disco privado, servir solo con URL firmada a admins.	Pendiente
6	IDs secuenciales: cualquiera recorre todos los perfiles, incluidos inactivos y de prueba.	/prestadores/{id}	Media	Slug público (`/hidrostyle`) y 404 para perfiles inactivos.	Pendiente
7	Los 6 prestadores figuran "Disponible" y "Atendiendo ahora" siempre.	Inicio, perfiles	Media	Calcular disponibilidad desde la agenda y el interruptor del barbero.	Pendiente
8	La licencia o título habilitante es obligatoria; la mayoría de los barberos no la tiene.	/register	Media	Hacerla opcional para barbería.	Pendiente
9	Email del pie `contacto@tutiempo.com` (sin .ar); los T&C usan `contacto@tutiempo.com.ar` .	Pie de página	Media	Corregir a `.com.ar` .	Pendiente

#	Hallazgo	Dónde	Severidad	Arreglo	Estado
10	Sin sitemap (/sitemap.xml no responde); robots.txt permite todo.	Raíz	Baja	Generar sitemap con perfiles activos.	Pendiente

Hallazgos de producto y UX

La promesa del inicio no coincide con lo que la app hace, y el perfil no da razones para confiar.

- **Promesa contradictoria.** El inicio dice "Sin turnos. Sin esperas. Servicio inmediato", pero los T&C 2.4 dicen que la reserva es una solicitud que el prestador puede aceptar o rechazar.
- **Precio sin servicio.** Las tarjetas de peluquería muestran $62.500 y $50.000 sin decir qué servicio es. Mostrar "desde $X · nombre del servicio".
- **Perfil pobre.** Hidro.Style tiene un solo servicio cargado, sin fotos de trabajos ni reseñas.
- **Sin agenda real.** No hay días ni horarios: el cliente no puede elegir cuándo ir.
- **Login obligatorio para ver el botón de reservar.** El cliente ve "Iniciá sesión para reservar" sin saber todavía si hay lugar.
- **Sin métricas.** No hay forma de saber dónde abandona el usuario. Instalar eventos de embudo: vista de perfil, elección de horario, inicio de pago, pago aprobado.

Legales y datos personales

Los T&C (versión 1.0, junio 2026) hay que actualizarlos antes de activar el cobro por la app. Conviene que lo revise el abogado.

- **4.5 Pagos.** Hoy dice que todos los pagos son exclusivamente entre cliente y prestador y que TuTiempo no interviene. Con el split de Mercado Pago, TuTiempo sí interviene en el cobro: reescribir.
- **4.7 Retribución.** Dice 20% de cada servicio con liquidación semanal. Ajustar a la regla que se decida (ver Decisiones pendientes) y a que se descuenta en el momento del cobro.
- **Política de cancelación y seña.** No existe. Agregar la regla decidida: lo pagado no se devuelve; si el cliente no va, el prestador se queda con lo pagado; si cancela el prestador, devolución total. Revisar con el abogado su encaje con la Ley de Defensa del Consumidor.
- **Ley 25.326.** El panel del barbero guarda notas, cumpleaños, teléfono e historial de faltas de cada cliente. Informarlo en la Política de Privacidad, pedir consentimiento al registrarse, y permitir que el cliente vea y borre sus datos.

- **DNI de prestadores.** Indicar finalidad, plazo de guarda y quién accede. Inscribir la base en la AAIP si corresponde (verificar con el abogado).
- **WhatsApp.** Los mensajes automáticos necesitan opt-in del cliente; el punto 1.8 lo cubre en parte, agregar cómo darse de baja con un toque.

Funcionalidades a construir

Todo esto está funcionando en el prototipo (ver Anexo); es la referencia de pantallas y comportamiento. Además: pestaña Productos (alta de productos, "Compré más" con cantidad y costo que suma stock y carga el gasto), vista "Ver como cliente" dentro del panel del barbero, Mi perfil y Mis turnos del cliente, eliminar cuenta (cliente: se borran sus datos y sus turnos se cancelan sin devolución; prestador: deja de aparecer y a sus clientes con turnos futuros se les devuelve todo), con confirmación en dos pasos, e inicio con filtro Todos / Barberías / Peluquerías y orden rotativo diario para que ningún prestador tenga ventaja.

Módulo	Lado	Qué hace
Ingreso	Cliente	Google OAuth o email + código de 6 dígitos. Sin contraseña. Vuelve al paso donde estaba.
Turnero	Cliente	Semana con barra de disponibilidad por día, botón "primer turno libre", horarios agrupados en mañana, tarde y noche (solo libres), barra fija con resumen y botón Reservar.
Pago del turno	Cliente	Seña o total por Mercado Pago, política de cancelación visible, revalidación del horario antes de cobrar.
Turno repetido	Cliente	Cada 2, 3 o 4 semanas: crea los próximos 3 turnos y saltea los ocupados. Se cobra en el momento la seña de todos y se muestra el total.
Mi turno	Cliente	Aviso grande al reservar ("¡Listo! Tenés turno… Tenés que ir"), "No voy a poder ir" sin devolución, cómo llegar, Google Calendar. Lista en "Mis turnos" (header) y banner del próximo turno en el inicio.
Lista de espera	Cliente	En un día lleno, "Avisame si se libera". Se notifica al cancelarse un turno de ese día.
Caja del día	Barbero	Cargar servicios sin turno y venta de productos (efectivo o Mercado Pago). Total por medio de pago.

Módulo	Lado	Qué hace
Agenda	Barbero	Línea de tiempo del día por origen (app, agendado, sin turno), huecos libres con botón "Ofrecer" a seguidores, detalle con Asistió / No vino / Cancelar, agendar manual, bloquear horario.
Horarios	Barbero	Turno mañana y turno tarde por día (por defecto 9–12 y 15–21), atajos de jornada, copiar lunes a todos, intervalo, anticipación máxima, aviso mínimo, seña o total, regla de faltas, happy hour con 5–30% o porcentaje libre (1 a 90).
Clientes	Barbero	Lista con filtros (para recuperar, fieles, con faltas, cumpleaños), ficha con notas del corte, historial, WhatsApp, "Te toca corte" masivo.
Finanzas	Barbero	Ganancia neta en 7 días, 30 días o año (con año anterior y tabla mes por mes), origen de la plata, comisión pagada, meta del mes, gastos. Un gasto de categoría Productos puede sumar unidades al stock.
Estadísticas	Barbero	Ocupación por semana (lunes a domingo, navegable), calendario del mes y promedio por mes del año, solo en horas de trabajo. Lista de sus horarios más flojos de las últimas 4 semanas, con atajos para armar un happy hour o avisar a seguidores.
Comunidad	Barbero	Seguidores, reseñas con respuesta, galería de fotos y videos, avisos a seguidores, QR y link.
Perfil	Barbero	Conectar Mercado Pago, datos, servicios y precios, cobertura, mensajes automáticos de WhatsApp editables.

Modelo de datos sugerido

Diez tablas cubren todo el prototipo. Montos en centavos (enteros), fechas en UTC y la zona horaria del prestador guardada aparte.

Tabla	Campos clave	Notas
`users`	id, nombre, email, celular, google_id, rol (cliente / prestador / admin), noshow_count	`noshow_count` alimenta la regla de faltas.
`providers`	id, user_id, slug, nombre, dirección, lat, lng, mp_user_id, mp_tokens (cifrados), dni_verificado, is_test	Slug único para la URL pública.
`services`	id, provider_id, nombre, duración_min, precio, activo	Un solo precio por servicio (en el local).
`schedules`	provider_id, día_semana, mañana_activa, mañana_desde, mañana_hasta, tarde_activa, tarde_desde, tarde_hasta	Una fila por día.
`booking_rules`	provider_id, intervalo_min, anticipación_días, aviso_min, cobro (seña / total), seña_pct, exigir_total_con_faltas, online_activo	Una fila por prestador.
`happy_hours`	provider_id, días (array), desde, hasta, descuento_pct, activo	
`bookings`	id, provider_id, client_id, service_id, tipo (app / manual / bloqueo / sin_turno), inicio, fin, precio, descuento_pct, pagado, estado (pendiente / confirmado / asistió / no_vino / cancelado), confirmó_asistencia, serie_id	Índice único parcial por prestador e intervalo para evitar dobles reservas.
`payments`	id, booking_id, mp_payment_id, monto, comisión, estado, reembolso	Fuente de verdad: webhook de Mercado Pago.
`client_notes`	provider_id, client_id, notas, cumpleaños, última_visita	Privado de cada prestador.

Tabla	Campos clave	Notas
`waitlist`, `followers`, `reviews`, `media`, `expenses`, `products`, `message_templates`	Tablas chicas de soporte	Ver módulos correspondientes.

Reglas de negocio

Estas reglas están implementadas y probadas en el prototipo; los valores son los de ejemplo, configurables por prestador.

1. **Horarios libres.** Un horario se ofrece si: el día está activo, el turno entra completo antes del cierre, no pisa el descanso, no pisa otro turno o bloqueo, está dentro de la anticipación máxima y respeta el aviso mínimo desde ahora.
2. **Doble reserva.** Antes de cobrar se revalida el horario. Si se ocupó, se cancela el cobro y se vuelve a elegir. En base de datos, la restricción de solapamiento es la última barrera.
3. **Seña.** 30% o 50% del precio con descuento, o el total. Clientes con 2 o más faltas pagan el total si el prestador activó la regla.
4. **Cancelación del cliente.** Lo pagado no se devuelve. El cliente puede tocar "No voy a poder ir": el horario se libera para la lista de espera y lo pagado queda para el prestador.
5. **Cambio de horario.** Desactivado por ahora (decisión de Carlos del 14/10/2026).
6. **Cancelación del prestador.** Devolución total y aviso automático a la lista de espera de ese día.
7. **No vino.** El prestador se queda con la seña y suma una falta al cliente.
8. **Happy hour.** Descuento automático sobre horarios de inicio dentro de la franja y días configurados.
9. **Comisión.** 20% sobre turnos pagados por la app. No se cobra sobre turnos agendados a mano, servicios sin turno ni productos.
10. **Login del prestador.** Bloqueo de 30 segundos tras 5 contraseñas incorrectas.

Cashback (saldo TuTiempo): eliminado en la versión 25. TuTiempo no guarda dinero de los clientes: se paga con Mercado Pago o en efectivo en el local. La tabla wallets queda en la base solo por compatibilidad y siempre está en 0.

Integraciones

Mercado Pago resuelve el cobro dividido de forma nativa; WhatsApp tiene costo por mensaje y hay que presupuestarlo.

Mercado Pago (split 1:1, marketplace) — documentación

- Cada prestador vincula su cuenta por OAuth desde "Conectar Mercado Pago"; se guarda su `access_token` y `refresh_token` cifrados.
- Checkout Pro: comisión de TuTiempo en `marketplace_fee` al crear la preferencia. Checkout API: `application_fee` en `/payments`. Verificar en la referencia si el valor es monto o porcentaje.
- La comisión de Mercado Pago se descuenta de lo que recibe el prestador; después se descuenta la de TuTiempo.
- Reembolsos: se restan proporcionalmente de prestador y marketplace. Si el prestador no tiene saldo, TuTiempo solo puede devolver su parte: definir cómo se cubre el resto.
- El estado del pago se toma del webhook, nunca de la redirección del navegador. Idempotencia por `mp_payment_id`.
- Para turnos repetidos, cobrar la seña 48 h antes requiere guardar el medio de pago del cliente o mandarle un link de pago: decidir cuál.

WhatsApp Business Platform — precios

- Desde julio de 2025 Meta cobra por plantilla entregada, según categoría (marketing, utility, authentication) y país. Argentina tiene tarifa propia en ARS.
- Confirmación y recordatorios son utility; "Te toca corte" y cumpleaños son marketing (más caros). Las utility son gratis si hay una conversación abierta en las últimas 24 h.
- Todas las plantillas necesitan aprobación de Meta antes de usarse. Conviene un proveedor (BSP) o la Cloud API directa.

Google

- Google OAuth para cliente y prestador. Pedir solo `openid email profile`.
- Agregar a Google Calendar con link `calendar/render?action=TEMPLATE` (como en el prototipo); no requiere API.

Seguridad

La app maneja dinero, DNI y datos personales: estos controles son mínimos, no opcionales.

- [ ] DNI y licencias en disco privado; acceso solo admin, con URL firmada y registro de quién lo vio.
- [ ] Tokens de Mercado Pago cifrados en base (`encrypted` cast de Laravel o equivalente).
- [ ] Verificar la firma de los webhooks de Mercado Pago.
- [ ] Rate limit en login, código por email (5 intentos, bloqueo temporal).
- [ ] Contacto del prestador visible para el cliente solo con turno pagado.

- [ ] Autorización por recurso: un prestador solo ve sus turnos, clientes, notas y finanzas (policies).
- [ ] HTTPS forzado, cabeceras de seguridad (HSTS, X-Content-Type-Options, Referrer-Policy) y cookies `Secure` y `SameSite`.
- [ ] Backups diarios de la base con prueba de restauración.

Diseño por segmento

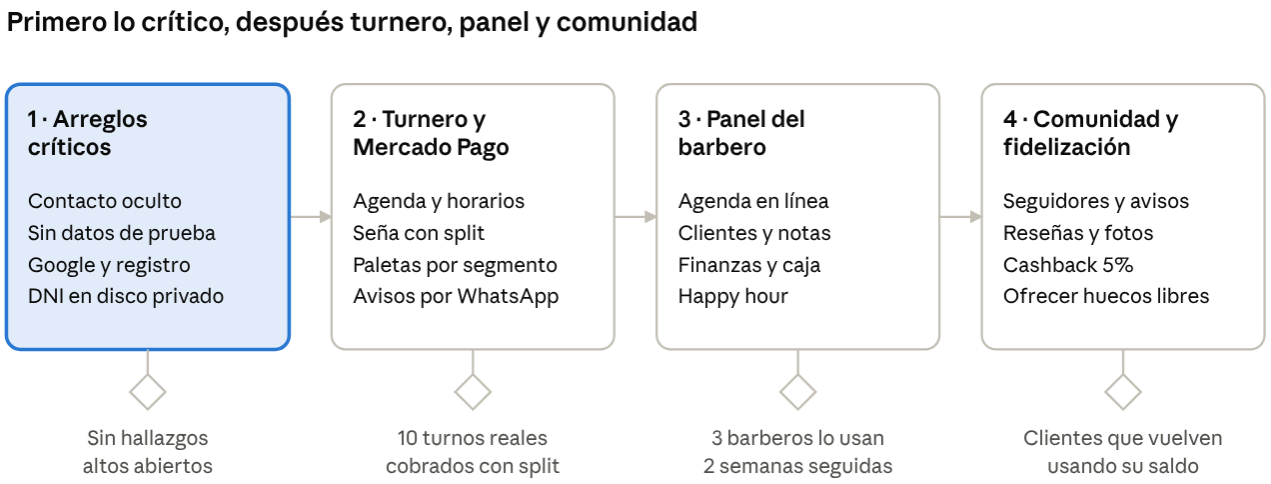
Cada segmento tiene su propia paleta y tipografía, y la pantalla entera cambia según lo que mira el cliente. El inicio y la cuenta usan una base neutra de TuTiempo para que ningún segmento tenga ventaja visual: barberías y peluquerías aparecen como dos tarjetas del mismo tamaño, lado a lado.

Segmento	Colores	Tipografía y forma	Dónde se aplica
TuTiempo (neutro)	Fondo `#F5F5F2`, tarjetas blancas, texto y botones `#121212`	Inter 800, bordes 16 px	Inicio con todos, Mis turnos, Mi perfil, login, registro, términos
Barberías	Negro `#000`, tarjetas `#0C0C0D`, texto `#F2F2F2`, botón blanco con texto negro, verde `#4ADE80` para confirmaciones	Barlow en mayúsculas con letras espaciadas, bordes de 4 a 6 px, cabecera con estrellas y brillo de horizonte (estética espacial e IA minimalista)	Filtro Barberías, perfil, pago y confirmación de una barbería, y el panel del prestador
Peluquerías	Fondo `#FAF5F2`, ciruela `#8C3A5E` (oscuro `#6F2B48`, suave `#F7E8EE`), texto `#2A1B22`	Títulos en Fraunces (serif), botones redondeados tipo píldora, bordes 20 px	Filtro Peluquerías, perfil, pago y confirmación de una peluquería

- Implementación: todo sale de variables CSS (`--bg`, `--card`, `--fg`, `--brand`, `--on-brand`, `--font-d`, `--r`, etc.) definidas tres veces. El `body` lleva `data-seg="n" | "b" | "p"` y cada tarjeta suelta (lista mezclada, Mis turnos) lleva la clase `seg-b` o `seg-p`.
- En producción conviene guardar el segmento en la tabla de prestadores (`categoria`) y elegir la paleta en el servidor para que no haya parpadeo al cargar.
- Fuentes desde Google Fonts: Inter, Barlow y Fraunces. Si no cargan, hay alternativas del sistema.
- No se usan logos ni marcas de terceros: la estética es una referencia, no una copia.

Plan por etapas

Cuatro etapas en orden; cada una tiene una condición medible para pasar a la siguiente. La etapa 1 lleva 1 a 2 semanas; el resto se estima después de cerrar las decisiones pendientes.



plan en 4 etapas · condición para pasar a la siguiente

Domicilio queda fuera de esta etapa de TuTiempo y ya no está en el prototipo. Si se retoma, entra como una etapa nueva, después de que el turnero tenga uso real.

Criterios de aceptación por etapa

- [ ] Etapa 1: ningún teléfono ni dirección visible sin turno pagado; /prestadores/1 da 404; un cliente reserva entrando con Google en menos de 1 minuto; los DNI no se abren por URL pública.
- [ ] Etapa 2: dos clientes no pueden pagar el mismo horario; el split aparece en las dos cuentas de Mercado Pago; si el cliente no va, lo pagado queda para el barbero, y si cancela el barbero se devuelve todo; el recordatorio de 24 h llega por WhatsApp.
- [ ] Etapa 3: el barbero carga un servicio sin turno en menos de 15 segundos; la ficha muestra notas en la agenda; la ganancia neta coincide con caja menos gastos.
- [ ] Etapa 4: un aviso a seguidores llega con link para reservar; el happy hour baja el precio solo en las franjas configuradas.

Decisiones pendientes de Carlos

Cinco definiciones de negocio cambian cómo se programa; conviene cerrarlas antes de la etapa 2.

- [ ] ¿La comisión del 20% se cobra también cuando un cliente propio del barbero reserva con su link, o solo con clientes nuevos que trae la app?

- [ ] Turnos repetidos: ¿se guarda la tarjeta del cliente para cobrar la seña 48 h antes, o se le manda un link de pago?
- [ ] Reembolso cuando el prestador no tiene saldo en Mercado Pago: ¿lo cubre TuTiempo o se le descuenta del próximo cobro?
- [ ] Resuelto en la versión 28: no se usa WhatsApp. Los avisos llegan dentro de la app, sin costo por mensaje.
- [ ] ¿Varios barberos por local entra en esta versión? Cambia el modelo: cada turno pasa a tener profesional asignado.

Anexo: prototipo y paquete para Hostinger

El prototipo es un único HTML sin backend: sirve como especificación visual y de comportamiento, no como código de producción.

- **Prototipo online:** TUTIEMPO Prototipo. La barra oscura de arriba cambia entre vista Cliente y Barbero.
- **Paquete para Hostinger:** `tutiempo-demo-hostinger.zip` con `index.html`, `.htaccess` (fuerza HTTPS, `noindex`) y `robots.txt`. Subir a un subdominio (`demo.tutiempo.com.ar`), nunca a la raíz del sitio real.
- **Usuarios de prueba:** cliente ya logueado (Juan Pérez); código por email `123456`. Barbero: `hidro.style@tutiempo.demo` / `barbero123`.
- **Datos de ejemplo:** reservas, clientes, finanzas, ocupación y reseñas son inventados. Hidro.Style es el único prestador con agenda completa.
- **Pruebas hechas sobre el prototipo:** 56 pasos del turnero, 37 de clientes, finanzas y mensajes, 36 de la versión sin domicilio con paletas por segmento, todas las pantallas a 360 px de ancho, y clics al azar sobre todos los botones, sin errores.

Fuentes

- Sitio actual: tutiempo.com.ar y sus Términos y condiciones
- Perfil de prueba publicado: /prestadores/1
- Mercado Pago: integrar marketplace (split 1:1)
- Meta: precios de WhatsApp Business Platform